**Автономная некоммерческая организация высшего образования**
**«Санкт-Петербургский институт экономики и управления»**

Кафедра **гуманитарных, математических и естественно научных дисциплин**

# ПРАКТИЧЕСКАЯ РАБОТА

Дисциплина(модуль)/предмет **МДК.03.02**

Тема: **Анализ угроз и уязвимостей информационной системы**

ВАРИАНТ № **3**

Студент (ка)/учащийся: **Браунков Матвей Константинович** / _____ /
Ф. И. О. подпись

Группа / Класс И14-23-9

Руководитель: **Чудинова А.А.** _____ /_____ /
Должность, степень, Фамилия и инициалы подпись

Дата представления работы «____» _____ 202__г.

Работа аттестована с оценкой _____
прописью

**Санкт-Петербург**
**2026 г.**

**СОДЕРЖАНИЕ**

ВВЕДЕНИЕ.....3
1 АРХИТЕКТУРА МОДУЛЯ И АНАЛИЗ УГРОЗ STRIDE.....4
2 МАТРИЦА ОЦЕНКИ РИСКОВ И ЭШЕЛОНИРОВАННАЯ ЗАЩИТА.....6
3 КОНТРОЛЬНЫЕ ВОПРОСЫ.....7
ЗАКЛЮЧЕНИЕ.....8
СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ.....9

# ВВЕДЕНИЕ

Цель работы: научиться анализировать архитектуру информационной системы на уязвимости, классифицировать угрозы по модели STRIDE [1] и стандарту ISO/IEC 25010 [2] и проектировать эшелонированную защиту (Defence-in-Depth, Zero Trust [3]).

Работа выполнена по варианту 3: модуль Climate Control (датчики и климат) АИС «Умный кампус». Ключевая область анализа – беспроводные IoT-датчики (Wi-Fi/Zigbee), атаки «человек посередине» (MitM) и подмена показаний.

# 1 АРХИТЕКТУРА МОДУЛЯ И АНАЛИЗ УГРОЗ STRIDE

## 1.1 Архитектурная схема и векторы атак

Датчики температуры и влажности в аудиториях передают показания по радиоканалу (Wi-Fi или Zigbee) на IoT-шлюз. Шлюз по MQTT или HTTPS отправляет данные в Climate API на .NET, которое сохраняет их в базе данных. Оператор через веб-панель задаёт уставки, и команды возвращаются контроллерам климата (вентиляция, отопление).

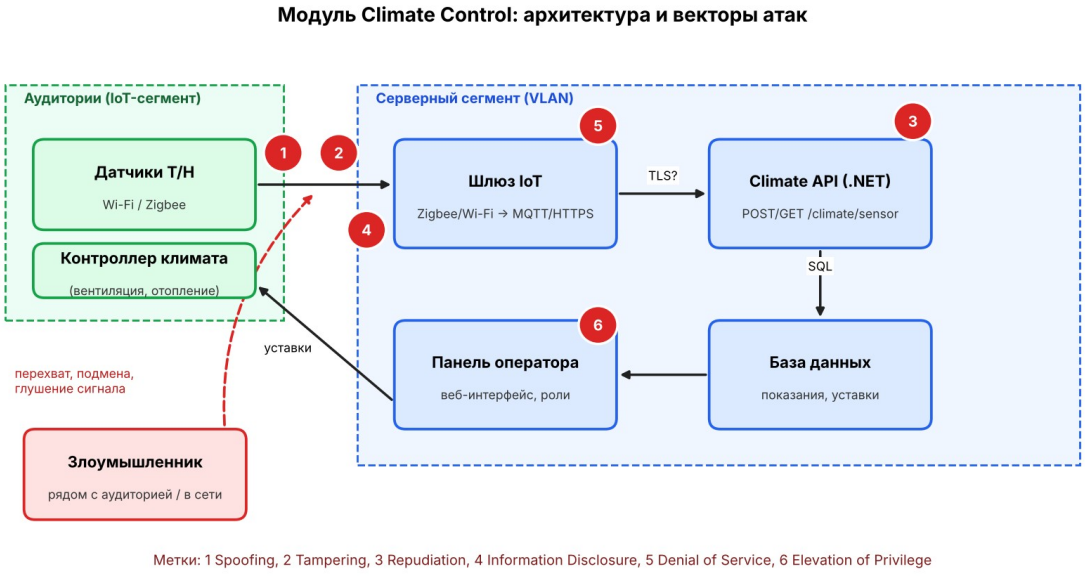



Рисунок 1 – Архитектура модуля Climate Control и векторы атак

Самое уязвимое место – радиоканал между датчиками и шлюзом: злоумышленнику, находящемуся рядом с аудиторией, не нужен доступ к сети кампуса. Остальные векторы – шлюз (перегрузка), API (отсутствие журнала и слабая авторизация) и панель оператора [4].

## 1.2 Анализ угроз по модели STRIDE

Таблица 1 – Угрозы STRIDE для модуля Climate Control

| **Категория STRIDE** | **Описание угрозы для модуля** | **Затронутая характеристика (CIA / ISO 25010)** |
|---|---|---|
| Spoofing | Злоумышленник подключает поддельный датчик с идентификатором настоящего и присылает ложные показания (метка 1) | Integrity; Security (аутентичность) |
| Tampering | При атаке MitM в радиоканале или шлюзе изменяется значение температуры, и климат-система включает отопление при жаре (метка 2) | Integrity; Security (целостность), Reliability |
| Repudiation | В API нет подписи показаний и журнала | Integrity; Security |

| | | |
|---|---|---|
| | изменений уставок, поэтому нельзя доказать, кто изменил настройки (метка 3) | (неотказуемость), Maintainability (анализируемость) |
| Information Disclosure | Перехват незашифрованного трафика раскрывает данные о заполненности аудиторий и расписании (метка 4) | Confidentiality; Security (конфиденциальность) |
| Denial of Service | Глушение Wi-Fi/Zigbee или поток запросов на шлюз и API останавливает поступление данных (метка 5) | Availability; Reliability (доступность) |
| Elevation of Privilege | Датчик или сервисная учётная запись получает права оператора на изменение уставок из-за слабой авторизации (метка 6) | Confidentiality, Integrity, Availability; Security (авторизация) |

# 2 МАТРИЦА ОЦЕНКИ РИСКОВ И ЭШЕЛОНИРОВАННАЯ ЗАЩИТА

## 2.1 Оценка рисков

Вероятность и ущерб оцениваются по шкале от 1 до 3, риск = вероятность × ущерб. Значения 6 и 9 – высокий риск, 3 и 4 – средний, 1 и 2 – низкий.

Таблица 2 – Матрица оценки рисков

| **Угроза** | **Вероятность** | **Ущерб** | **Риск** | **Уровень** |
|---|---|---|---|---|
| Spoofing | 3 | 2 | 6 | Высокий |
| Tampering (MitM) | 2 | 3 | 6 | Высокий |
| Repudiation | 2 | 2 | 4 | Средний |
| Information Disclosure | 2 | 2 | 4 | Средний |
| Denial of Service | 2 | 3 | 6 | Высокий |
| Elevation of Privilege | 1 | 3 | 3 | Средний |

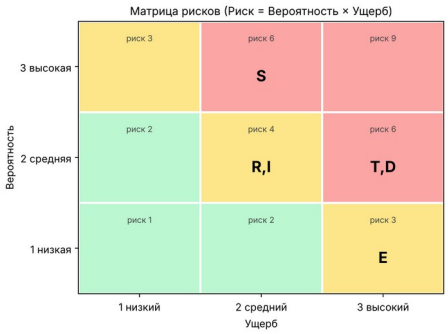



Рисунок 2 – Расположение угроз в матрице рисков

## 2.2 Трёхуровневый профиль защиты

Таблица 3 – Эшелонированная защита

| **Уровень** | **Меры** | **Нейтрализуемые угрозы** |
|---|---|---|
| Аппаратный / сетевой | Отдельная IoT-VLAN и межсетевой экран; WPA3-Enterprise для Wi-Fi, сетевой ключ и install code для Zigbee; TLS 1.2+ между шлюзом и API; шлюз с TPM для хранения ключей; контроль физического доступа (СКУД) к щитам и шлюзам | Spoofing, Tampering, Information Disclosure, DoS |
| Программный (код и ОС) | Валидация DTO (температура -50…60 °C, влажность 0…100 %); [Authorize] и роли [5]; подпись показаний (HMAC) с меткой времени и одноразовым номером; ограничение частоты запросов; журнал аудита; принцип Least Privilege для учётных записей; паттерн «Адаптер» для изоляции старых датчиков; EDR на шлюзе | Spoofing, Tampering, Repudiation, DoS, Elevation of Privilege |
| Организационный | Политика паролей и смена заводских паролей шлюзов; обучение сотрудников против фишинга; регламент обновления прошивок датчиков; регулярный аудит журналов и прав доступа | Elevation of Privilege, Repudiation, Spoofing |

## 3 КОНТРОЛЬНЫЕ ВОПРОСЫ

### 1. Чем отличается Spoofing от Elevation of Privilege?

Spoofing – подмена личности: нарушитель выдаёт себя за другого пользователя или устройство (например, поддельный датчик). Elevation of Privilege – получение прав выше выданных: уже аутентифицированный субъект выполняет действия, которые ему запрещены (например, датчик меняет уставки).

### 2. Почему HTTPS/TLS не защищает от SQLi и XSS?

TLS шифрует канал между клиентом и сервером, но не проверяет содержимое запроса. Вредоносная строка с SQL-кодом или скриптом приходит по защищённому каналу и после расшифровки попадает в приложение.

### 3. Что такое Zero Trust при проектировании REST API?

Принцип «никому не доверяй, всегда проверяй» [3]: каждый запрос проверяется независимо от того, из какой сети он пришёл. В API это означает аутентификацию и авторизацию каждого вызова ([Authorize], проверка токена и прав), валидацию входных данных, минимальные права и журналирование.

### 4. Как защититься от Replay Attack?

Нужно сделать каждое сообщение уникальным и ограниченным по времени [6]: добавлять метку времени и одноразовый номер (nonce) к подписанному запросу, хранить использованные номера, отклонять устаревшие сообщения, использовать короткоживущие токены.

### 5. Почему EDR и Firewall бессильны против вишинга и Email Spoofing без SPF/DKIM/DMARC?

Вишинг и подделка отправителя атакуют человека, а не программу: сотрудник сам сообщает пароль или выполняет просьбу, и технически это легитимные действия. Без SPF, DKIM и DMARC [7] почтовый сервер не может проверить, что письмо действительно отправлено от имени домена, поэтому поддельное письмо проходит фильтры.

# ЗАКЛЮЧЕНИЕ

Для модуля Climate Control выявлено шесть угроз по одной на каждую категорию STRIDE, оценены риски (три высоких, три средних) и сопоставлены с характеристиками ISO/IEC 25010 и триадой CIA. Наиболее опасными оказались подмена показаний, MitM в радиоканале и отказ в обслуживании.

Предложен трёхуровневый профиль защиты: сетевой (VLAN, WPA3, TLS, TPM), программный (валидация, авторизация, подпись показаний, аудит) и организационный (пароли, обучение, обновления). Совместное применение уровней снижает риски, даже если один из рубежей будет преодолён.

# СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. Microsoft Learn. Threat modeling: STRIDE [Электронный ресурс]. – URL: https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats (дата обращения: 30.10.2026).

2. ISO/IEC 25010:2011. Systems and software engineering – Systems and software Quality Requirements and Evaluation (SQuaRE) – System and software quality models [Электронный ресурс]. – URL: https://iso25000.com/index.php/en/iso-25000-standards/iso-25010 (дата обращения: 30.10.2026).

3. NIST SP 800-207. Zero Trust Architecture [Электронный ресурс]. – URL: https://csrc.nist.gov/pubs/sp/800/207/final (дата обращения: 30.10.2026).

4. OWASP. IoT Security Verification Standard / IoT Top 10 [Электронный ресурс]. – URL: https://owasp.org/www-project-internet-of-things/ (дата обращения: 30.10.2026).

5. Microsoft Learn. Authorization in ASP.NET Core [Электронный ресурс]. – URL: https://learn.microsoft.com/en-us/aspnet/core/security/authorization/introduction (дата обращения: 30.10.2026).

6. OWASP. Replay Attack [Электронный ресурс]. – URL: https://owasp.org/www-community/attacks/Replay_attack (дата обращения: 30.10.2026).

7. RFC 7489. Domain-based Message Authentication, Reporting, and Conformance (DMARC) [Электронный ресурс]. – URL: https://datatracker.ietf.org/doc/html/rfc7489 (дата обращения: 30.10.2026).